

Interne memo – advies implementatie van ISO 27001

Groep: Firewall Force

Leden: Vo, Jonas, Lucas, Bavli



Aanleiding

De organisatie is begonnen met het opzetten van een informatiebeveiligingssysteem volgens **ISO 27001**. De directie wil weten hoe het security team hier goed aan kan bijdragen, welke andere afdelingen betrokken moeten worden en wat er nodig is om veilig werken echt onderdeel te maken van de dagelijkse praktijk. In deze memo geven wij daar advies over.

Waarom ISO 27001

ISO 27001 is een framework dat organisaties helpt om informatiebeveiliging gestructureerd aan te pakken. Het gaat dus niet alleen om technische beveiliging, maar ook om beleid, verantwoordelijkheden, controles en continue verbetering. Dat past goed bij een organisatie die beveiliging niet los wil zien van de rest van de bedrijfsvoering.

Rol van het security team

Het security team heeft bij de invoering van ISO 27001 een trekkende rol. Dat team moet niet alles alleen doen, maar wel richting geven, risico's in beeld brengen en afdelingen ondersteunen.

In de eerste fase is het belangrijk dat het security team samen met management en IT kijkt naar de belangrijkste risico's. Denk aan datalekken, phishing, zwakke wachtwoorden, onvoldoende toegangsbeheer of systemen die niet op tijd gepatcht worden. Op basis daarvan kan worden bepaald welke informatie en processen het belangrijkst zijn om te beschermen.

Daarna helpt het security team bij het opstellen van beleid en praktische regels. Bijvoorbeeld over toegangsrechten, omgaan met gevoelige informatie, incidentmeldingen en thuiswerken. Belangrijk is dat dit niet alleen op papier staat, maar ook uitvoerbaar is in de praktijk.

Vervolgens moet het security team maatregelen helpen invoeren. Dat kunnen technische maatregelen zijn, zoals multi-factor-authenticatie, logging, encryptie en netwerkbeveiliging. Maar ook organisatorische maatregelen, zoals duidelijke verantwoordelijkheden, controles en trainingen.

Tot slot moet het security team blijven controleren of maatregelen werken. Dat betekent audits uitvoeren, incidenten evalueren, risico's opnieuw bekijken en verbeteringen voorstellen. ISO 27001 is geen eenmalig project, maar een proces van steeds bijsturen en verbeteren.

Samenwerking met andere stakeholders

Een belangrijk punt uit de workshop is dat je communicatie moet aanpassen aan je doelgroep. Dat geldt hier ook.

De **directie** wil vooral weten wat de risico's zijn voor de organisatie, wat de mogelijke schade is en waarom investeringen nodig zijn. Voor deze groep moet het security team dus vooral duidelijk

en zakelijk communiceren. Niet te technisch, maar juist gericht op continuïteit, reputatie en compliance.

Het **management** kijkt meer naar de uitvoering binnen afdelingen. Zij willen weten wat haalbaar is, wat het kost in tijd en hoe security kan worden ingevoerd zonder processen onnodig te verstoren. Hier is een praktische aanpak belangrijk.

De **IT-afdeling** en eventuele securityspecialisten hebben juist meer behoefte aan technische details. Met deze groep moet je concreter spreken over kwetsbaarheden, configuraties, monitoring en oplossingen.

Ook **medewerkers** zijn een belangrijke stakeholder. Uiteindelijk hangt veilige uitvoering voor een groot deel af van hun gedrag. Als medewerkers niet begrijpen waarom regels bestaan, worden maatregelen sneller omzeild of vergeten.

Ondersteuning van management en teams

Het security team moet management en teams vooral helpen om veilig werken haalbaar te maken. Dat betekent dat beveiliging zoveel mogelijk moet aansluiten op bestaande processen. Security werkt beter wanneer het niet alleen wordt opgelegd, maar ook logisch voelt in het dagelijkse werk.

Een goed voorbeeld is het invoeren van MFA. Dat is een extra stap voor gebruikers, maar het verlaagt wel duidelijk het risico op ongeautoriseerde toegang. Als zo'n maatregel goed wordt uitgelegd en eenvoudig wordt ondersteund, is de kans groter dat medewerkers die accepteren.

Daarnaast is awareness belangrijk. Eén training per jaar is niet genoeg. Beter is een combinatie van korte bewustwordingsmomenten, phishing-simulaties en duidelijke communicatie over actuele risico's. Zo blijft informatiebeveiliging terugkomen zonder dat het te zwaar wordt.

Het security team ondersteunt de organisatie door:

- Integratie van security in dagelijkse werkprocessen (security by design)
- Implementatie van gebruiksvriendelijke beveiligingsmaatregelen
- Training en begeleiding van medewerkers
- Opstellen van praktische richtlijnen en procedures

Hierbij is het belangrijk dat security niet als obstakel wordt gezien, maar als onderdeel van efficiënte bedrijfsvoering.



Concrete maatregelen

Wij adviseren om minimaal de volgende maatregelen op te nemen in de implementatie:

- invoeren van multi-factor-authenticatie;
- periodieke controle op toegangsrechten;
- opstellen van een duidelijk informatiebeveiligingsbeleid;
- incident response procedure invoeren;
- awareness-trainingen en phishing-oefeningen organiseren;
- systemen regelmatig updaten en monitoren;
- back-up en herstelprocedures testen.

Deze maatregelen zijn concreet, toepasbaar en sluiten goed aan op de uitgangspunten van ISO 27001.

Advies aan de directie

Ons advies aan de directie is om informatiebeveiliging niet alleen als technisch onderwerp te zien, maar als een organisatiebreed vraagstuk. De implementatie van ISO 27001 slaagt alleen als er steun is vanuit bovenaf en als afdelingen samenwerken.

De directie moet daarom duidelijke prioriteit geven aan informatiebeveiliging, eigenaarschap beleggen binnen de organisatie en het security team mandaat geven om verbeteringen door te voeren. Tegelijk moet er ruimte zijn voor een realistische invoering, zodat maatregelen ook echt werkbaar blijven.

Conclusie

Het security team heeft een centrale rol in de implementatie van ISO 27001, maar kan dit niet alleen. Succes hangt af van goede samenwerking, duidelijke communicatie en maatregelen die passen bij de praktijk van de organisatie. Als de directie hierin actief stuurt en het onderwerp breed laat terugkomen, kan informatiebeveiliging een vast onderdeel worden van de dagelijkse manier van werken.